

Identifying Threats (Part 1)

Who attacks, from where, and how

420-1C2-DW Threats and Risks · Class 4 · Topic 3

Monday, November 2, 2026 · 6:00–10:00 pm · Online

AEC (Attestation d'études collégiales) Cybersecurity: Prevention and Intervention (LEA.D8)

Cyber.SoHo Educational Hub

Educational material — Cyber.SoHo / Asen Grozdanov · © 2026 · Kalmia Coffee Roasters Inc. is fictional

The one fact to remember

A threat becomes a risk only where it meets a vulnerability in an asset you care about



Every threat you record tonight points to a Kalmia asset and to the evidence that makes it relevant.

The lecture hour — four lessons on the clock



0:00–0:04	Opening — the one fact, objectives, legal notice
0:04–0:19	Lesson 1 — External threat actors and their motivations
0:19–0:31	Lesson 2 — Internal threats
0:31–0:50	Lesson 3 — Common attack methods
0:50–1:00	Lesson 4 — Case study: a recent attack on a small organization

After the hour: Quiz 01 (administered separately) · Hours 2–3: the code examples in teams · Lab 1 due Thursday 23:59

By the end of this hour you will be able to

1. Profile the four external threat actor types by motivation, capability, intent and targeting
2. Distinguish malicious insiders, negligent users and third parties — and treat indicators as facts, not accusations
3. Explain five attack methods, the **CIA** (Confidentiality, Integrity, Availability) property each one violates, and how they chain
4. Analyse a real ransomware case from public sources: what is known, what is not
5. Turn each threat into a Lab 2 row: threat source, threat event, asset, evidence, source

Kalmia Coffee Roasters Inc. — what an attacker would see

46 employees · $6.8 M

Roastery in Saint-Laurent; cafés on the Plateau, in Old Montréal and in Laval

Web shop = 25% of revenue

One third of online sales in November and December

Flat roastery network

NAS-01 holds the shares; its only backup disk stays connected

ROAST-PC on Windows 10

Vendor remote access (RoastLink) with a shared password

MFA on 2 accounts only

The two Microsoft 365 administrator accounts

Incidents INC-02 to INC-05

Fake bank details · **POS** (point of sale) outage · loyalty export · phishing texts

Kalmia (Torréfaction Kalmia inc.) is the fictional case organization of the course.

Three rules for tonight — Legal Notice v2.0

Study threat information — never act on it

- No leak sites, no contact with threat actors, no breach data
- Legal Notice, section 7.3

No social engineering of real people

- The phishing samples are fictional
- Phishing or pretexting a real person is prohibited (6.3, 7.7.3)

Attribution only as the source states it

- Ganong and KNP are discussed from public sources only
- Sections 7.3 and 7.9

Full terms: Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy (v2.0)

1

LESSON 1 · 0:04 – 0:19

External threat actors and their motivations



In this lesson

- Threat, threat source, threat actor
- Four questions that profile any actor
- Cybercriminals · hacktivists · state-sponsored groups · opportunistic attackers
- Micro-activity, example, code and Schematic 1

From assets to threats — the words of the catalogue



Threat

Any circumstance or event that can harm operations, assets or people through unauthorized access, destruction, disclosure, modification of information or denial of service



Threat source

Who or what causes the harm



Threat actor

A threat source that is a person or a group acting on purpose

Adversarial
people who intend harm

Accidental
mistakes by people who mean well

Structural
failures of equipment, software, controls

Environmental
fire, flood, outage of an outside service

External threat actor = no authorized access: no account, no badge, no contract. Everything it gets, it must take. (**NIST** [National Institute of Standards and Technology] glossary; **NIST SP** [Special Publication] 800-30)

Four questions that profile any threat actor



Motivation

- Why does it act?
- Money · ideology · geopolitics · satisfaction · discontent
- Written in words



Capability

- What can it do?
- Skills, money, time, tools, people
- Rated 1–5



Intent

- What does it want from us — and how determined is it?
- Rated 1–5



Targeting

- Us specifically, or anyone exposed?
- Rated 1–5

NIST SP 800-30 scale: 1 very low · 2 low · 3 moderate · 4 high · 5 very high — every rating needs evidence and a source

Cybercriminals (1/2) — money, organized as a service

- Motivation: financial · sophistication: varies widely (Cyber Centre)
- Cybercrime-as-a-service: criminals specialize and sell to one another (**NCTA** [National Cyber Threat Assessment] 2025-2026)
  - Ransomware-as-a-service: developers rent ransomware to affiliates
  - Initial access brokers: break into companies, then sell the access
  - Passwords stolen by information stealers; kits for fake login pages
- Every step is bought ready-made — attacking a 46-person roaster costs very little



Most frequent attackers of small companies

Organization, not genius: every step of the attack can be bought.

Cybercriminals (2/2) — Kalmia has already met them

- INC-02 (June): a look-alike of the importer's domain announces new bank details
  - The account is changed in Sage 50; $18,400 is stopped by a call-back on a known number
  - Business email compromise (**BEC**): a fraud that needs no malware
- What the same actors would want at Kalmia:
  - NAS-01 files → ransomware · checkout page → card-skimming code
  - 18,500 loyalty records → resale or extortion
- **NCTA**: ransomware is the top cybercrime threat to critical infrastructure; fraud and scams are the most common cybercrime affecting Canadians



INC-02

$18,400 saved by one phone call to a known number.

Hacktivists — a cause and an audience

- Motivation: a political or social cause; success means visibility
- Methods: **DDoS** (distributed denial of service), defacement (home page replaced by their message), leaks
- Capability: generally lower; free or rented tools (Cyber Centre)
- **NCTA**: geopolitically motivated hacktivists are unpredictable; pro-Russia non-state actors ran **DDoS** campaigns against Canadian websites in 2023
- Two realistic routes to Kalmia:
  - Direct — a dispute about its “direct-trade” claims
  - Collateral — many Canadian shops flooded during a political event



Asset at risk

Web shop availability in November–December (a third of online revenue) and Kalmia's reputation.

State-sponsored groups (1/2) — the highest capability

- Work for, or with the support of, a government
- Motivation: espionage, theft of intellectual property, preparing disruption, influence — money for some states
- Dedicated teams, custom tools, months hidden in a network: advanced persistent threat (**APT**)
- Cyber Centre assessment (**NCTA** 2025-2026):
  - China, Russia and Iran: the greatest strategic cyber threats; China's program is the most sophisticated and active
  - North Korea: ransomware and cryptocurrency theft to fund the regime
  - India: building capabilities; likely espionage against Government of Canada networks



Legal Notice 7.3

We report what the Cyber Centre assesses. We never attribute an incident to a state ourselves.

State-sponsored groups (2/2) — why a coffee roaster still matters

- Kalmia holds nothing a state wants: no government contracts, no defence data
- Route 1 — edge devices: routers, firewalls, **VPN** (virtual private network) gateways
  - Chinese and Russian actors routed attacks through compromised **SOHO** (small office / home office) routers in Canada and the United States
  - Kalmia's three café routers are **SOHO** devices
- Route 2 — supply chain: compromise a supplier to reach its customers
  - InfoNord **MSP** (managed service provider) holds administrator rights in Kalmia's Microsoft 365
- Kalmia is a possible relay or passenger — rarely the final target



Relevance: moderate

Very high capability, very low intent toward Kalmia — the row stays in the catalogue.

Opportunistic attackers — exposure is the only criterion

- No chosen victim: automated scans of the whole Internet for a known weakness
- Includes thrill-seekers (often called script kiddies) and botnets that recruit any device they can log in to
- Low capability, near-zero targeting — and the activity never stops
- Mirai (2016): cameras and routers that kept their default passwords flooded websites (**CISA** [Cybersecurity and Infrastructure Security Agency] TA16-288A)
- Kalmia: two of its seven cameras keep their factory passwords; four web-shop plugins have not been updated for six months



The key idea of Lesson 1

You cannot change an attacker's motivation. You can change your exposure.

Lesson 1 — micro-activity and video

Micro-activity — Match the actor to the evidence (2 min)

(1) A supplier's “new banking details” arrive from a look-alike domain

(2) The web shop goes offline on the day of a national political announcement, with forty other Canadian shops

(3) A café router is found relaying traffic for a foreign intrusion campaign

(4) A camera that kept its factory password joins a botnet

For each fact: which actor type, and which motivation?

Videos (15 min or less) — after class

Threat Actors — CompTIA Security+ SY0-701 — 2.1

Professor Messer · 10:23 min · Watch on YouTube

Practice in the HTML module

5 flash-cards · formative quiz: 4 multiple-choice + 2 multiple-select questions

Real-life example 1 — who would attack Kalmia, and why?

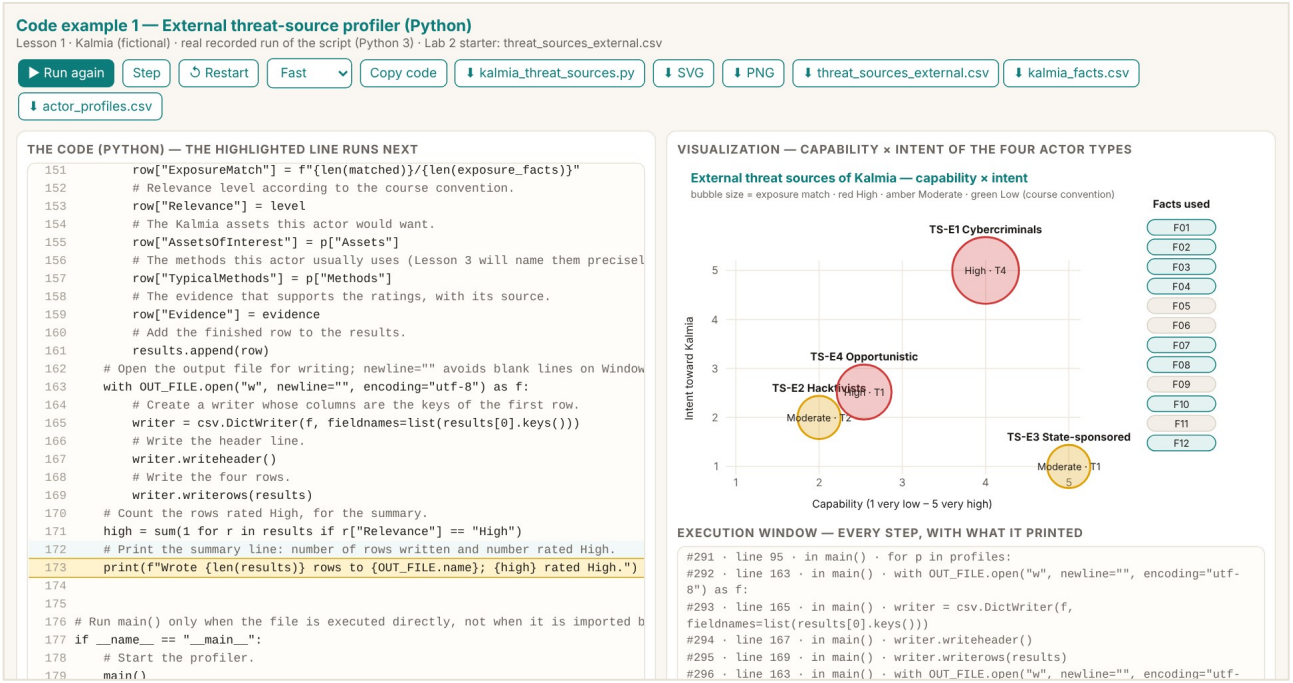
Threat source	Capability	Intent	Targeting	Exposure match	Relevance
TS-E1 Cybercriminal groups	4	5	4	4 of 4	▲ High
TS-E2 Hacktivists	2	2	2	2 of 2	● Moderate
TS-E3 State-sponsored groups	5	1	1	2 of 2	● Moderate
TS-E4 Opportunistic attackers	2	2	1	3 of 3	▲ High

Lowest skill, yet High: opportunistic attackers match 3 of 3 of Kalmia's documented weaknesses.

Course rule: High if intent ≥ 4 with capability ≥ 3, or exposure ≥ 3 · Moderate if intent ≥ 3 or exposure ≥ 2 · otherwise Low. Relevance ranks the Lab 2 rows; likelihood is rated in Topic 5.

Code example 1 — external threat-source profiler (Python)

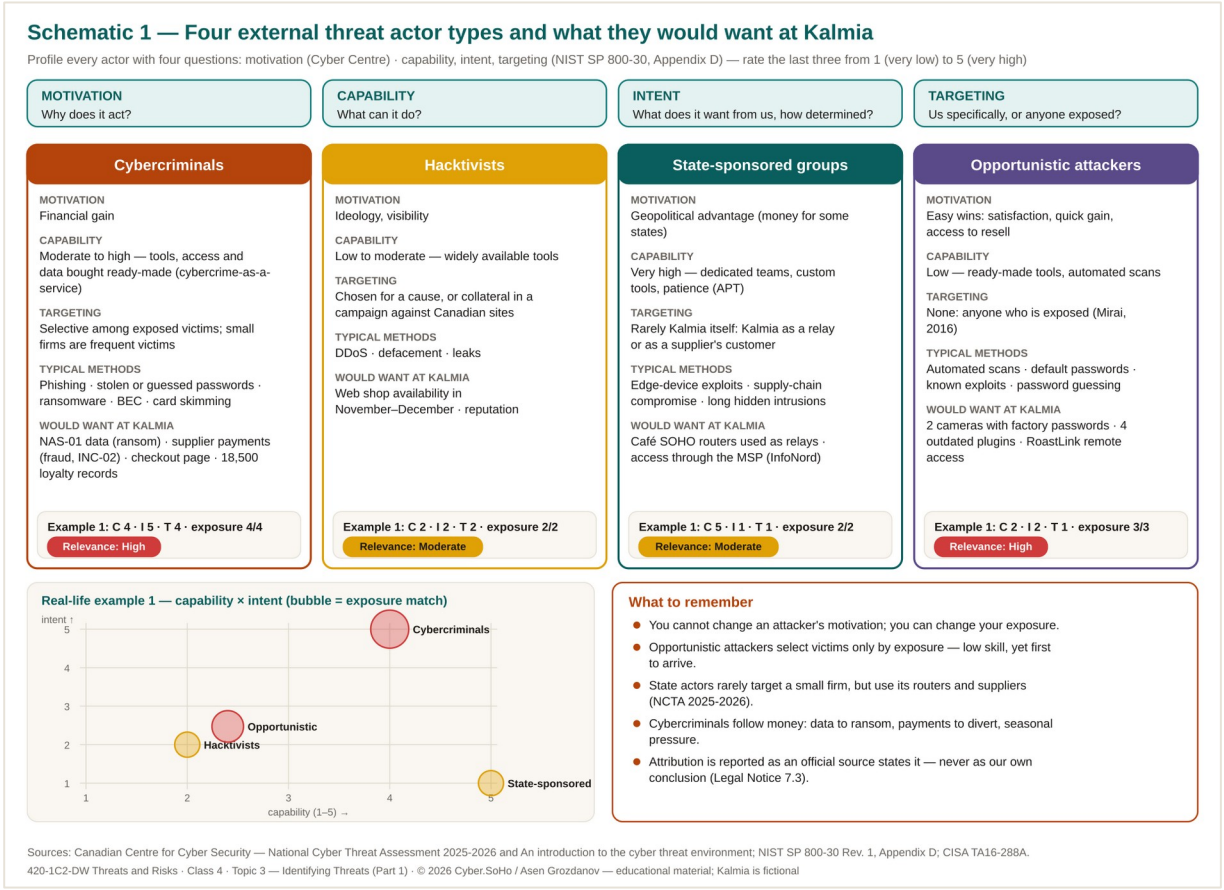
1. Reads kalmia_facts.csv (12 facts) and actor_profiles.csv (4 actors)
2. Intent = base value + weights of the facts that attract the actor, kept between 1 and 5
3. Targeting rises with each reason to pick Kalmia specifically
4. Counts the weaknesses that match the actor's methods (exposure match)
5. Applies the relevance rule, prints each decision and draws the bubble
6. Writes threat_sources_external.csv — the Lab 2 starter rows



The interactive runner of the **HTML** module: Start / Pause, Step, Restart, Copy, downloads

Run it: python kalmia_threat_sources.py — or press Start in the HTML (HyperText Markup Language) module

Schematic 1 — four external threat actor types



How to read it

- Top row: the four profiling questions — motivation, capability, intent, targeting
- One column per actor type: motivation, capability, targeting, typical methods, what it would want at Kalmia
- Foot of each column: the ratings of Real-life example 1 and the relevance
- Bottom: the capability × intent bubble chart and what to remember

Motivation, capability, targeting, typical methods and what each actor would want at Kalmia, with the bubble chart of Real-life example 1

2

LESSON 2 · 0:19 – 0:31

Internal threats



In this lesson

- Who counts as an insider (**CISA** [Cybersecurity and Infrastructure Security Agency])
- Malicious insiders · negligent and accidental users
- Third parties and suppliers
- Indicators are not proof — then example, code and Schematic 2

Who counts as an insider

Insider

Any person who has, or had, authorized access to or knowledge of the organization's resources (**CISA**)

Insider threat

The potential to use that access or knowledge — on purpose or by mistake — to harm the organization

Two key words

“Had”: a former employee whose account still works · “Knowledge”: knowing how payments are approved, even without an account

Unintentional	**Intentional**	Collusive	Third-party
negligence or accident	malicious insiders	an insider working with an outsider	contractors and vendors with access

Course outline families: malicious insiders · negligent users · third parties and suppliers

Malicious insiders — normal actions, wrong context

- Use legitimate access to steal, commit fraud, sabotage or take revenge; often motivated by discontent (Cyber Centre)
- The action looks like normal work — the difference is the context: time, volume, person, need
- INC-04: a shift supervisor left on July 15; her loyalty administrator account was never disabled
  - September 18, 21:47 — 18,500 member records exported; found on October 2 after a complaint
  - Known: a former employee's account exported data · Unknown: who typed the password, and why
- Law 25: a confidentiality incident — record it; notify the **CAI** (Commission d'accès à l'information du Québec) and the people concerned if there is a risk of serious injury



The analyst's role

Record the facts and the indicator. The investigation decides the rest.

Negligent and accidental users — the most common insider

- Negligent: knows the rule and ignores it · Accidental: makes an honest mistake
- They cause harm directly, and they are the people external attackers manipulate
- INC-02: the employee who changed the bank details had no bad intent — two catalogue rows:
  - the fraudster (external threat source) and a payment process one e-mail can change (internal condition)
- Kalmia's documents already show:
  - one manager **PIN** (personal identification number) shared by the shift leads of each café
  - the NAS-01 administrator password shared by four people
  - an **HR** (human resources) form scanned into a folder every employee can read



Not attacks — openings

Each practice makes an attack easier, or makes it impossible to know who did what.

Third parties and suppliers — their access becomes the attacker's

- Outside organizations or people given access to do their work: **MSP** (managed service provider), software vendor, freelancer, cloud service
- Verizon 2025 **DBIR** (Data Breach Investigations Report): third-party involvement in 30% of breaches — twice the previous year's share
- Kalmia's third parties with access:
  - InfoNord **MSP** — global administrator in Microsoft 365; manages the firewall
  - RoastTech — unattended remote access to ROAST-PC, shared password, no end date
  - Émile Gagnon — WordPress administrator without **MFA** (multi-factor authentication) · cloud **POS** (point of sale), loyalty and payroll providers
- Harm without an attacker: INC-03, the **POS** outage — a supplier failure (structural, not adversarial)



Supply chain

A supplier's access, service and identity (INC-02 used the importer's name) all belong in the catalogue.

Indicators are not proof

Observable facts that may signal an insider threat

- An account of a former employee still active or used
- A bulk export by someone who never exports
- Access at an unusual time
- A vendor session outside the agreed window
- One person creates bank details and releases the payment
- Nine refunds in forty minutes under a shared **PIN**

Lab 2

Record the indicator, the asset, the **CIA** (Confidentiality, Integrity, Availability) property at stake and the source document

Lab 4

Propose the control: offboarding checklist, individual **PINs**, vendor-session approval, a second approver

Never

Name a person as guilty — not the analyst's role (Legal Notice 7.5 and 18)

Lesson 2 — micro-activity and videos

Micro-activity — Malicious, negligent or third party? (3 min)

(1) The account of a supervisor who left in July exports the loyalty list

(2) A barista writes the manager **PIN** under the cash drawer

(3) RoastTech connects to ROAST-PC at 02:14 without a ticket

(4) An employee changes a supplier's bank details after a convincing e-mail

(5) The freelance developer installs a plugin downloaded from a forum

(6) An **HR** form is scanned into the folder that everyone can read

Vote for each situation.

Videos (15 min or less) — after class

Supply Chain Attacks — CompTIA A+ 220-1202 — 2.5
Professor Messer · 8:04 min · Watch on YouTube

Business Email Compromise — CompTIA A+ 220-1202 — 2.5
Professor Messer · 5:59 min · Watch on YouTube

Practice in the HTML module
5 flash-cards · formative quiz: 4 multiple-choice + 2 multiple-select questions

Real-life example 2 — Kalmia's accounts and audit logs

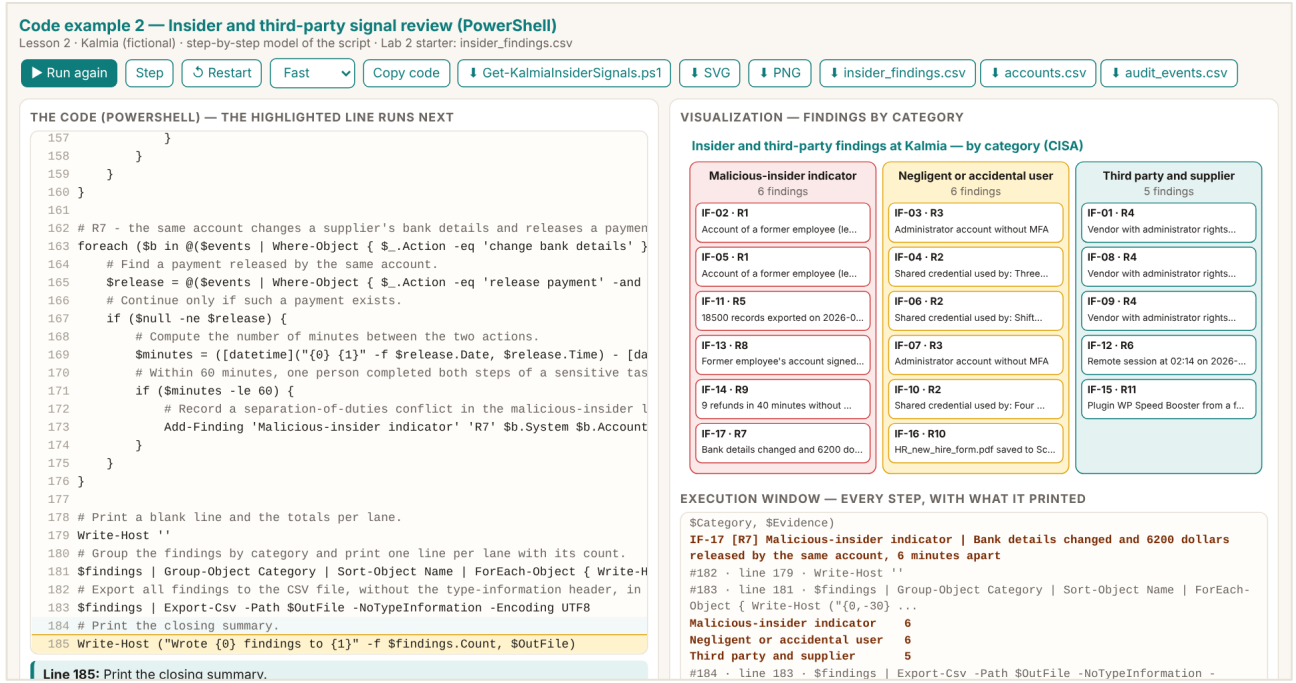
Category	Finding	Evidence	CIA
Malicious-insider indicator	Former employee's account exported personal data	Loyalty platform, Sept 18, 21:47, 18,500 records (INC-04)	C
Malicious-insider indicator	Burst of refunds under a shared **PIN**	**POS**, Café Plateau, 9 refunds in 40 minutes	I
Malicious insider or compromised account	A leaver's account signed in from a new device	Microsoft 365, Oct 26 (left Aug 28)	C
Negligent or accidental user	**HR** form saved where everyone can read it	NAS-01 Scans share	C
Third party and supplier	Vendor session outside the agreed window	RoastLink, Oct 19, 02:14, 48 min, no ticket	I, A
Separation-of-duties conflict	Same person changed bank details and released the payment	Sage 50, Oct 21, 6 minutes apart, $6,200	I

Eight of the thirteen accounts would be harmless with three controls: offboarding, named accounts and MFA.

Two findings have more than one explanation (training error? stolen password?): the catalogue lists the threat event; the incident procedure verifies.

Code example 2 — insider and third-party signals (PowerShell)

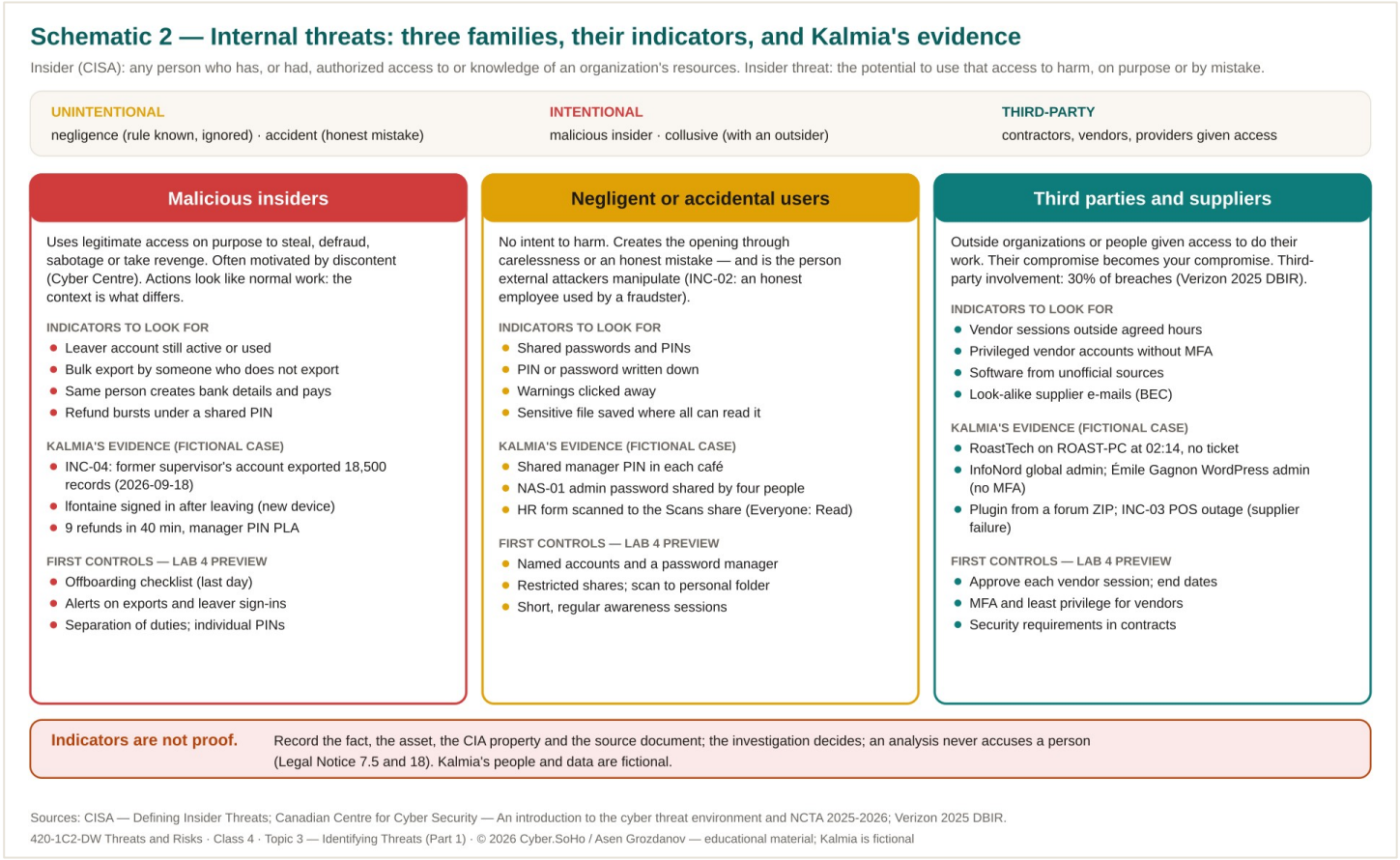
1. Imports accounts.csv (13 accounts) and audit_events.csv (10 events)
2. Account rules R1–R4: leavers still active, shared accounts, administrators without **MFA**, vendor accounts
3. Event rules R5–R11: bulk export, unusual hours, refund bursts, vendor sessions outside the window, unofficial software
4. R7 checks separation of duties: the same person changes bank details and releases the payment
5. 17 findings — malicious 6 · negligent 6 · third party 5 — written to insider_findings.csv



The interactive runner of the **HTML** module: Start / Pause, Step, Restart, Copy, downloads

Run it on the Windows lab VM (virtual machine): .\Get-KalmiaInsiderSignals.ps1 (PowerShell 7 or 5.1)

Schematic 2 — internal threats



How to read it

- Top band: the **CISA** types — unintentional, intentional (incl. collusive), third-party
- Three columns: malicious insiders · negligent or accidental users · third parties and suppliers
- In each column: indicators to look for, Kalmia's evidence, first controls (Lab 4 preview)
- Bottom banner: indicators are not proof

Malicious insiders, negligent or accidental users, and third parties and suppliers, with the **CISA** definitions, typical indicators, Kalmia's evidence (INC-04, INC-02, RoastLink, shared **PINs**) and the first controls that Lab 4 will develop.

3

LESSON 3 · 0:31 – 0:50

Common attack methods



In this lesson

- Actor, method, tool — and the threat event
- Malware · ransomware · phishing and social engineering
- Denial of service · credential theft
- How methods chain — then example, code, Schematic 3 and the 2025 numbers

Actor, method, tool — and the threat event

Threat actor	The person or group
Attack method	What the actor does — trick a person, guess a password, flood a server
Tool	What it uses — a piece of malware, a phishing kit, a botnet

Threat event — a column of the Lab 2 catalogue

“Ransomware encrypts NAS-01 after a phishing e-mail” is a threat event; “a ransomware group” is a threat source.

Class 5 gives each event its MITRE ATT&CK technique identifier — tonight only a preview.

Malware — unwanted code that must be delivered

- A program inserted without consent to compromise confidentiality, integrity or availability (**NIST** [National Institute of Standards and Technology] **SP** [Special Publication] 800-83)
- Families you will meet most often:
  - trojan · virus · worm · spyware and keyloggers · information stealers
- Delivery is the step you can block:
  - an attachment that asks to “enable content” · a fake update · a **USB** (Universal Serial Bus) stick
  - a vulnerable service exposed to the Internet · a trusted update tampered with at the supplier

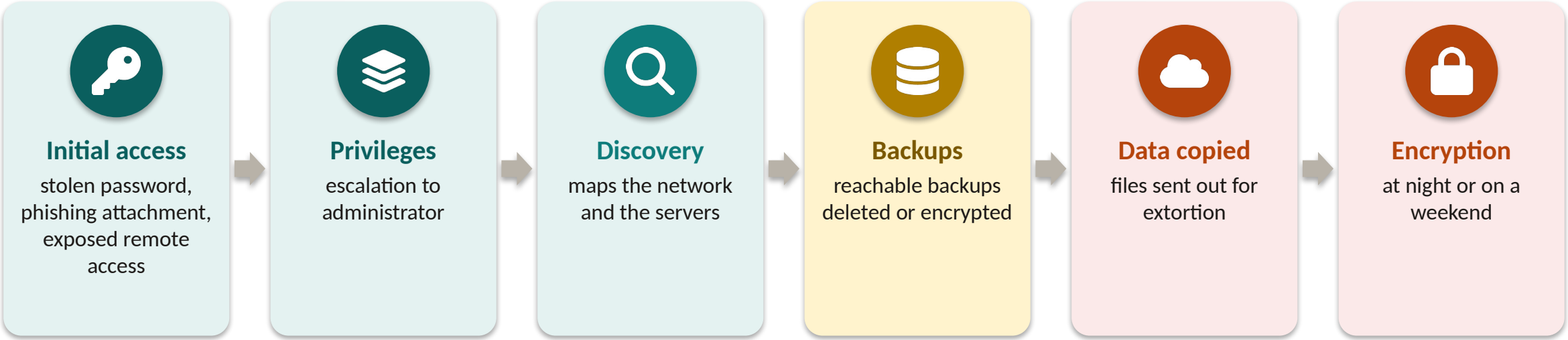


Kalmia — event E1

An invoice attachment with a macro: do not open, report, block macros from the Internet.

Ransomware (1/2) — encrypt and extort

- Encrypts files or locks systems and demands payment for the key
- Double extortion: data is copied out first, then publication is threatened — a confidentiality and an availability incident



Hours or weeks between the first and the last stage — each stage is a chance to detect and stop the attack.

Ransomware (2/2) — small companies, and why the backup decides

88%
of breaches at small and medium-sized businesses involved ransomware

39%
at large organizations

44%
of all breaches analysed

64%
of victims did not pay (median payment $115,000)

Source: Verizon 2025 Data Breach Investigations Report

At Kalmia the stages already have names

- Initial access: a Microsoft 365 account without **MFA** (multi-factor authentication), or RoastLink
- Free movement on the flat roastery network
- NAS-01 and its always-connected backup disk encrypted together

Phishing and social engineering (1/2) — channels and goals



E-mail

- The classic channel
- Spear phishing: real names and details
- **BEC** (business email compromise): aimed at a payment



Smishing

- By text message
- INC-05: “your schedule changed — log in here”



Vishing

- By voice call
- A caller “from InfoNord” asks for the **POS** (point of sale) manager **PIN** (personal identification number)



QR codes

- Lead to a fake login page
- The real address is hidden

Three goals: make the victim run malware · type a password on a fake page · act directly (change bank details, buy gift cards, read a **PIN** aloud)

Phishing and social engineering (2/2) — levers and red flags

Red flags that follow from the levers

- Sender domain that is almost right
- Reply-to address different from the sender
- Link text that does not match the real address
- Unexpected attachment that asks to enable macros
- A request to bypass the normal procedure



Urgency

“Today before 3 pm”



Authority

The **CEO** (chief executive officer), the bank, the **IT** (information technology) provider



Fear or reward · familiar context

So that nothing seems odd

Samples in this module are fictional. Sending phishing or pretexting to a real person is prohibited (Legal Notice 6.3 and 7.7.3).

Denial of service — availability only

- **DoS** (denial of service): makes a service unavailable to its legitimate users
- **DDoS** (distributed denial of service): from many machines at once — usually a botnet of computers, cameras and routers
- Some floods exhaust the bandwidth; others send requests that are expensive for the server (search, checkout)
- Nothing is stolen, nothing is changed — but nobody can buy
- Favourite method of hacktivists; also sold as a service and used for extortion



Kalmia

A checkout flood in the last week of November. But not every outage is an attack: INC-03 was a supplier failure.

Credential theft — log in instead of breaking in

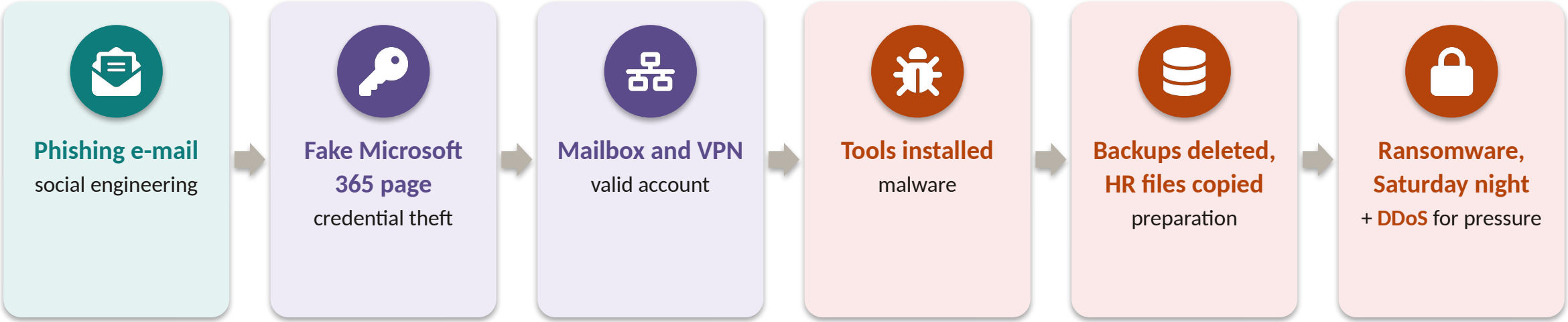
- Credential: password, **PIN**, session cookie, one-time code
- Guessing and brute force · password spraying (one password, many accounts) · credential stuffing (pairs leaked elsewhere)
- Phishing pages · information stealers
- **CISA** (Cybersecurity and Infrastructure Security Agency) AA23-352A (Play): abuse of valid accounts is a usual way in
- **MFA** blocks most stolen-password attacks — so attackers use **MFA** fatigue (push bombing)
  - Defence: number matching or phishing-resistant methods; an unexpected request means someone has your password



Kalmia

MFA on the two Microsoft 365 administrators only; nine staff accounts, the loyalty administrators and three WordPress administrators rely on a password alone.

How the methods chain into one attack



One control can break several methods at once

- **MFA** stops the stolen password
- An offline backup removes the pressure to pay
- One person who reports the first e-mail stops everything

Lesson 3 — micro-activity and videos

Micro-activity — Find the six red flags (3 min) — fictional training e-mail

From: Café Sol Importation <comptes@cafesol-importation.co>

Reply-To: payments.cafesol@outlook-mail.net

Subject: URGENT — new banking details for invoice 4471 · Attachment: Facture_4471.docm

“Please update before 3 pm today; our bank changed after an audit. Click ‘Enable content’ to see the new account. Do not call, our phones are down.”

List every red flag. This sample is fictional and must never be sent to anyone.

Videos (15 min or less) — after class

An Overview of Malware — CompTIA Security+ SY0-701 — 2.4
Professor Messer · 6:06 min · Watch on YouTube

Social Engineering — CompTIA A+ 220-1202 — 2.5
Professor Messer · 13:37 min · Watch on YouTube

Denial of Service — CompTIA A+ 220-1202 — 2.5
Professor Messer · 4:52 min · Watch on YouTube

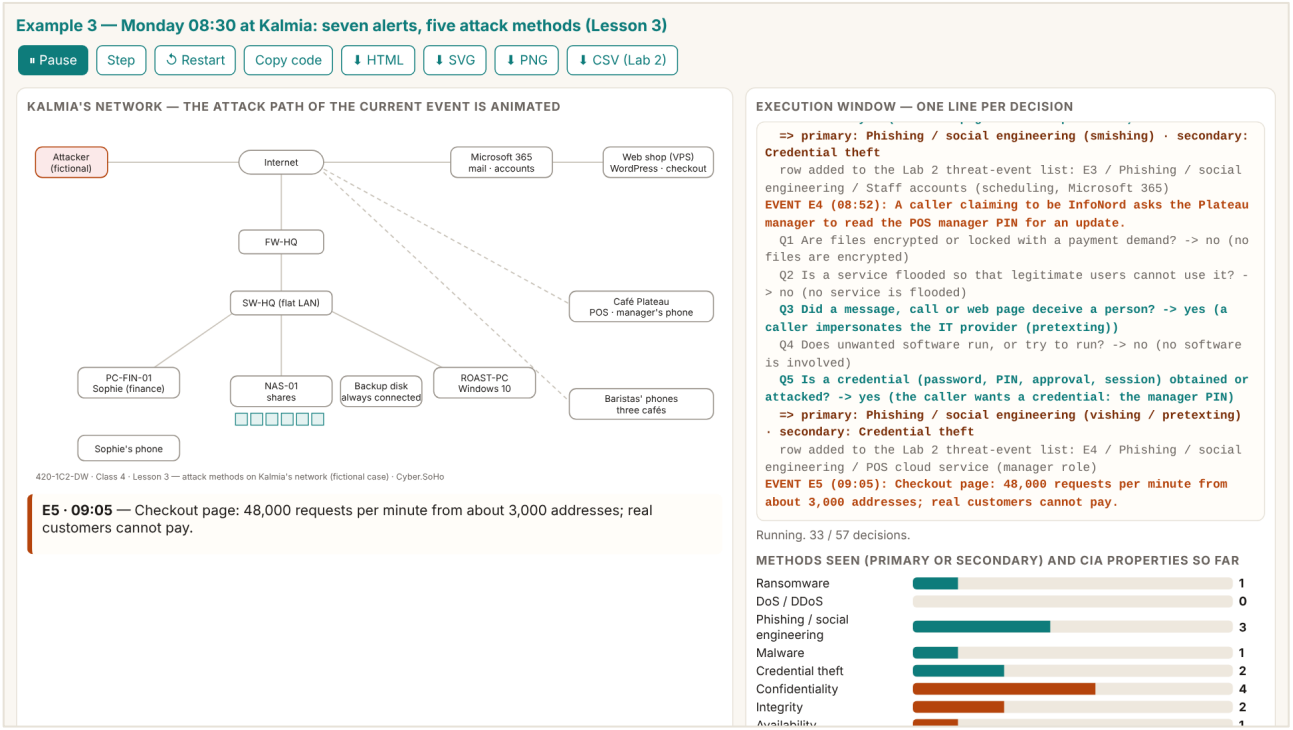
Real-life example 3 — seven events at Kalmia

Event	What was observed	Primary method	CIA
E1	“Facture_4471.docm” from a look-alike domain asks to “Enable content”	Phishing (spear phishing)	I, C
E2	NAS-01 files renamed *.locked; the backup disk is encrypted too	Ransomware	A, C
E3	**SMS** (Short Message Service, a text message) to baristas: “Your schedule changed — log in at …”	Phishing (smishing)	C
E4	A caller “from InfoNord” asks for the **POS** manager **PIN**	Social engineering (vishing)	C, I
E5	Checkout: 48,000 requests per minute from 3,000 addresses	**DDoS**	A
E6	WordPress: 1,240 failed logins in 10 minutes from 180 addresses	Credential theft (spraying)	C
E7	14 Microsoft 365 approval requests at 23:10; the 15th is approved	Credential theft (**MFA** fatigue)	C

E3, E4 and E7 start differently but all end in credential theft — two different catalogue rows: the method that obtains the credential, and its use.

Code example 3 — attack-method identifier (HTML / JavaScript)

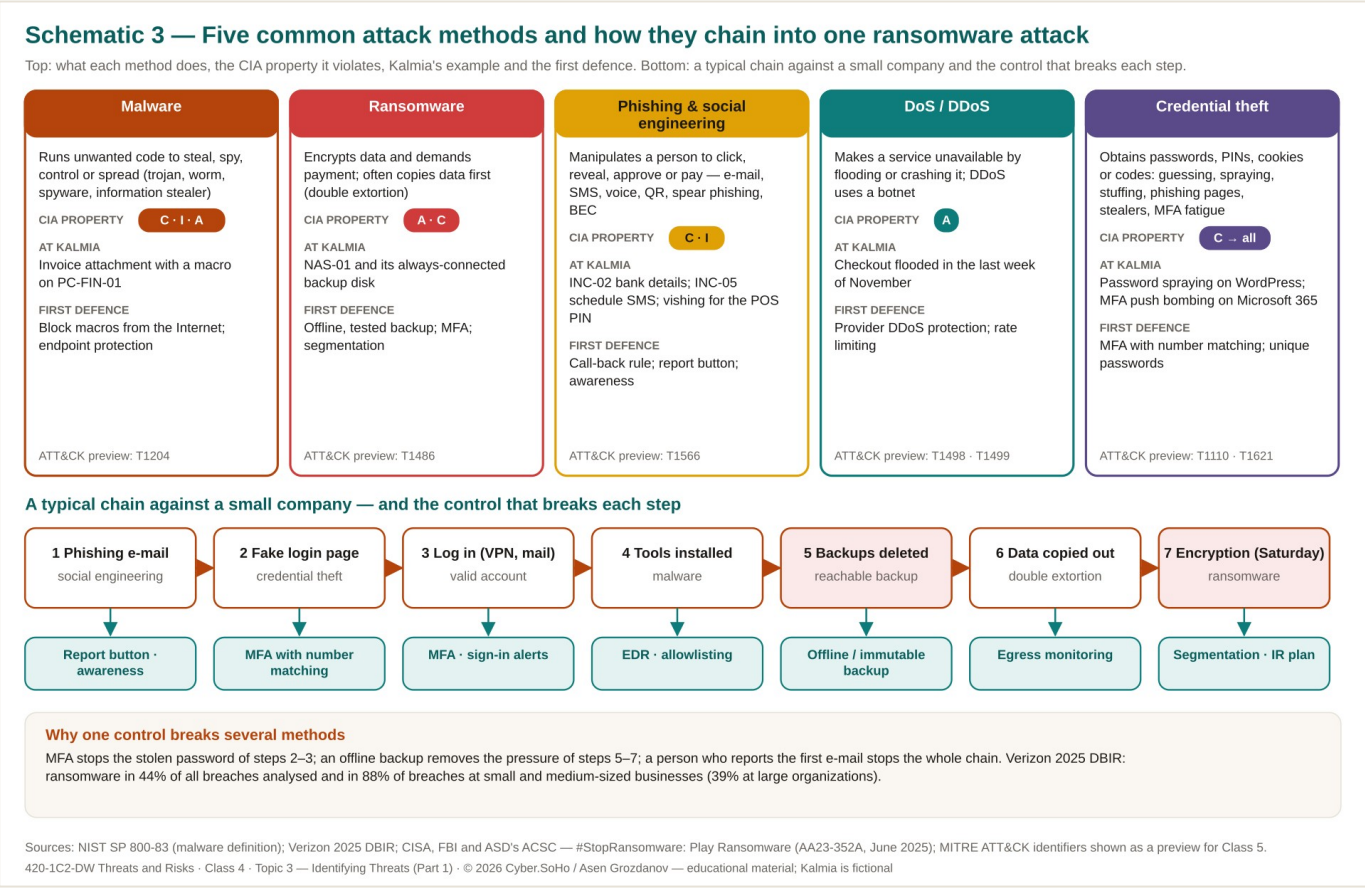
1. Seven Kalmia events (E1–E7) are classified one after the other
2. Five ordered questions: encrypted for payment? flooded? deception? unwanted software? credential obtained?
3. The network map animates the attack path of the current event
4. Counters show every method seen and the **CIA** (Confidentiality, Integrity, Availability) properties at stake
5. Each decision adds a row to the Lab 2 threat-event table (**CSV** [comma-separated values] download)



The interactive runner of the **HTML** module: Start / Pause, Step, Restart, Copy, downloads

Open kalmia_attack_method_identifier.html in any browser — it works offline

Schematic 3 — five attack methods

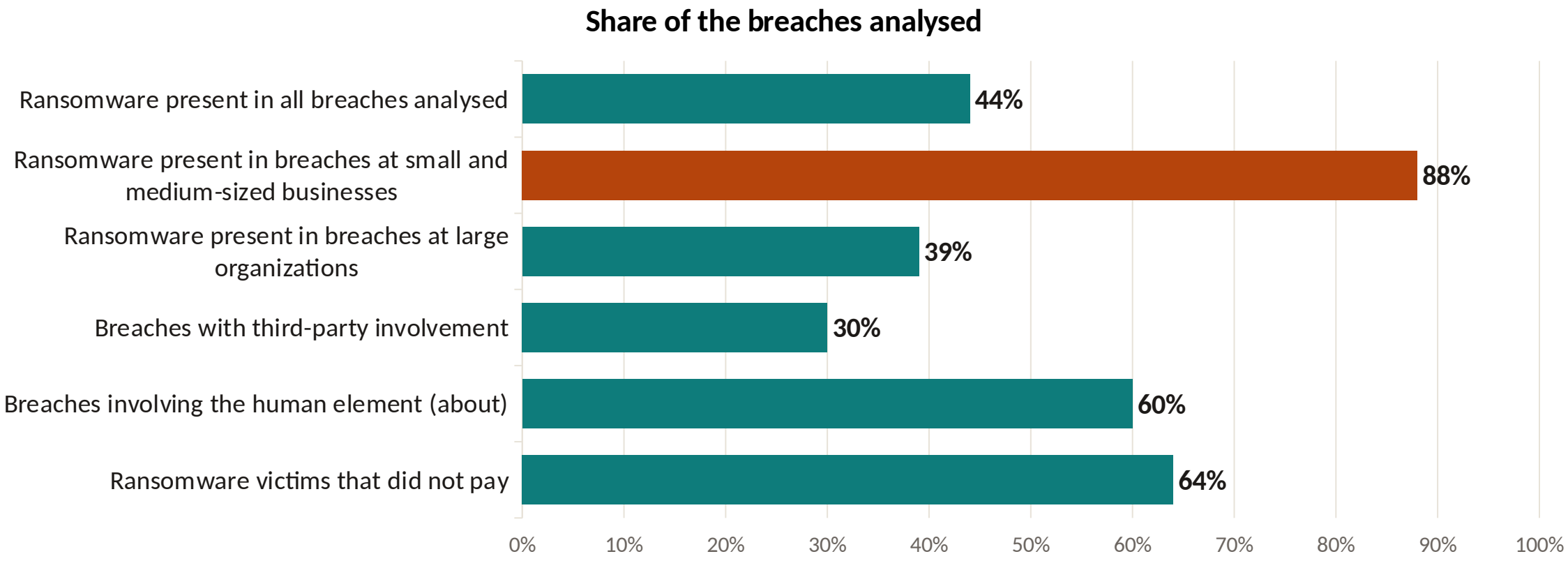


How to read it

- Top: each method with what it does, the **CIA** property it violates, the Kalmia example and the first defence
- Grey line in each card: the MITRE ATT&CK identifier (preview for Class 5)
- Bottom: a typical chain against a small company in seven steps
- Under each step: the control that breaks it

Top: the five methods with what each does, the **CIA** property it violates and the first defence. Bottom: a typical chain against a small company — phishing, stolen credential, malware, backup deletion, data copy, encryption — with the control that breaks each step.

The threat landscape in six numbers — Verizon 2025 DBIR



Share of the confirmed breaches analysed in the 2025 **DBIR**. The rust bar is the figure that concerns Kalmia most. Source: Verizon, 2025 Data Breach Investigations Report.

4

LESSON 4 · 0:50 – 1:00

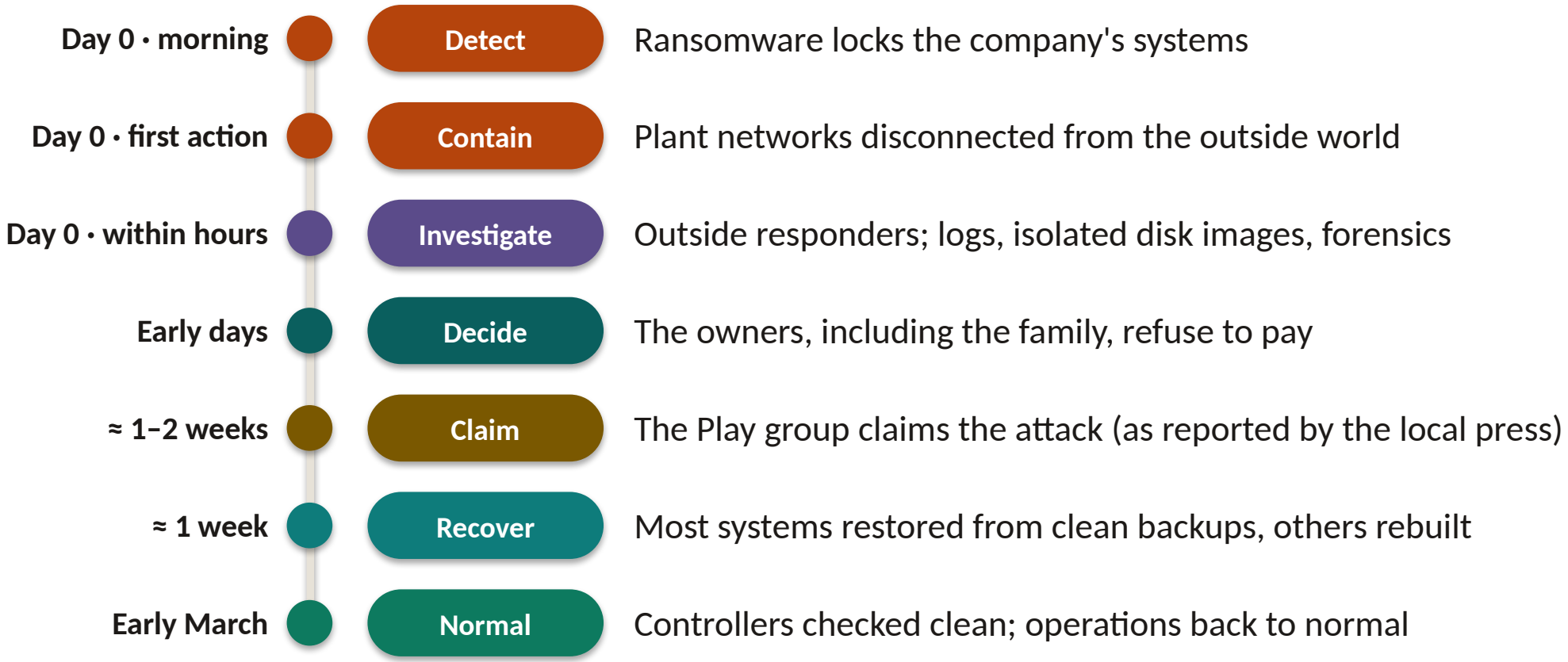
Case study: a recent attack on a small organization



In this lesson

- Ganong Bros., Limited — family-owned chocolate and candy maker, founded in 1873 in St. Stephen (New Brunswick)
- Ransomware on Saturday, February 22, 2025 — documented first-hand by its head of **IT** (information technology)
- What saved it — and the other ending: KNP Logistics
- Would Kalmia survive the same Saturday?

What happened — Saturday, February 22, 2025, and after



Sources: CSO Online (account by the head of **IT**, August 2025) · CHCO-TV / The Courier (company statement, March 2025)

What we know about the attackers — and what we do not

CISA AA23-352A (CISA, FBI, ASD's ACSC; updated June 4, 2025)

- About 900 affected organizations as of May 2025
- Usual initial access: valid accounts · **RDP** (Remote Desktop Protocol) and **VPN** (virtual private network) exposed to the Internet · known vulnerabilities in public-facing products
- Data stolen before encryption (double extortion)

Known

Ransomware with double extortion; the Play group claimed it (reported as the sources state it)

Not stated

How the attackers first got in — never fill that gap with a guess

Write

“Ransomware group of the Play type; usual initial access according to **CISA** (Cybersecurity and Infrastructure Security Agency) AA23-352A …” — not “Play got in through the **VPN**”

What saved the company

Offline backups

- The decisive factor: restore instead of pay

Isolation first

- Networks cut from the outside in the first hour

Responders within hours

- Logs, disk images and forensics

Controllers checked

- Production restarted only on clean machinery controllers

Adopted afterwards: written ransomware scenarios · a backup way to communicate · leadership tabletop exercises · stricter vendor requirements · sharing lessons with the sector

The other ending — KNP Logistics (2023)

- A 158-year-old transport company in England, about 500 trucks
- **BBC** (British Broadcasting Corporation) Panorama (July 21, 2025): the attackers guessed one employee's password
- Data encrypted, systems locked — although its **IT** met industry standards and it had cyber insurance
- Demand estimated by specialists at up to £5 million — which it could not pay
- The data could not be recovered: the company closed and about 700 people lost their jobs



Same attack, opposite outcomes

The difference is what the victim had prepared: authentication a guessed password cannot defeat, and a backup the attacker cannot reach.

Real-life example 4 — would Kalmia survive the same Saturday?

Measure seen in the case	Kalmia today (its own documents)	Status
Clean offline backup	Only backup disk always connected to NAS-01	▲ Missing
Rapid isolation	Flat roastery network; no isolation procedure	▲ Missing
Outside responders within hours	**MSP** (managed service provider) contract covers patching and helpdesk only	● Partial
Ransom decision by the owners	Nadia Roy is the risk owner; no written position	● Partial
Controllers checked before restart	ROAST-PC on Windows 10 with vendor remote access	▲ Missing
Backup communication · tabletop · vendor rules	Everything on Microsoft 365; no plan; no vendor requirements	▲ Missing
Authentication a guessed password cannot defeat	**MFA** (multi-factor authentication) on 2 accounts only; shared RoastLink password	▲ Missing

Kalmia today resembles KNP more than Ganong — Topics 4 to 7 will verify each fact and rate each risk.

Wholesale sales at risk (Class 1: about $9,500 per working day): ≈ $47,500 with a clean backup (5 days) vs ≈ $142,500 without one (15 days) — illustrations, not ratings.

Lesson 4 — micro-activity and video

Micro-activity — Would Kalmia survive the same Saturday? (2 min)

(1) Could Kalmia disconnect only the infected part of its network within one hour?

(2) Does Kalmia have a copy of NAS-01 that ransomware on the network could not reach?

(3) If e-mail and Teams were down, does every manager know how to reach the others and the IT provider?

Answer yes or no in the chat before the reveal.

Videos (15 min or less) — after class

Password Attacks — CompTIA A+ 220-1202 — 2.5

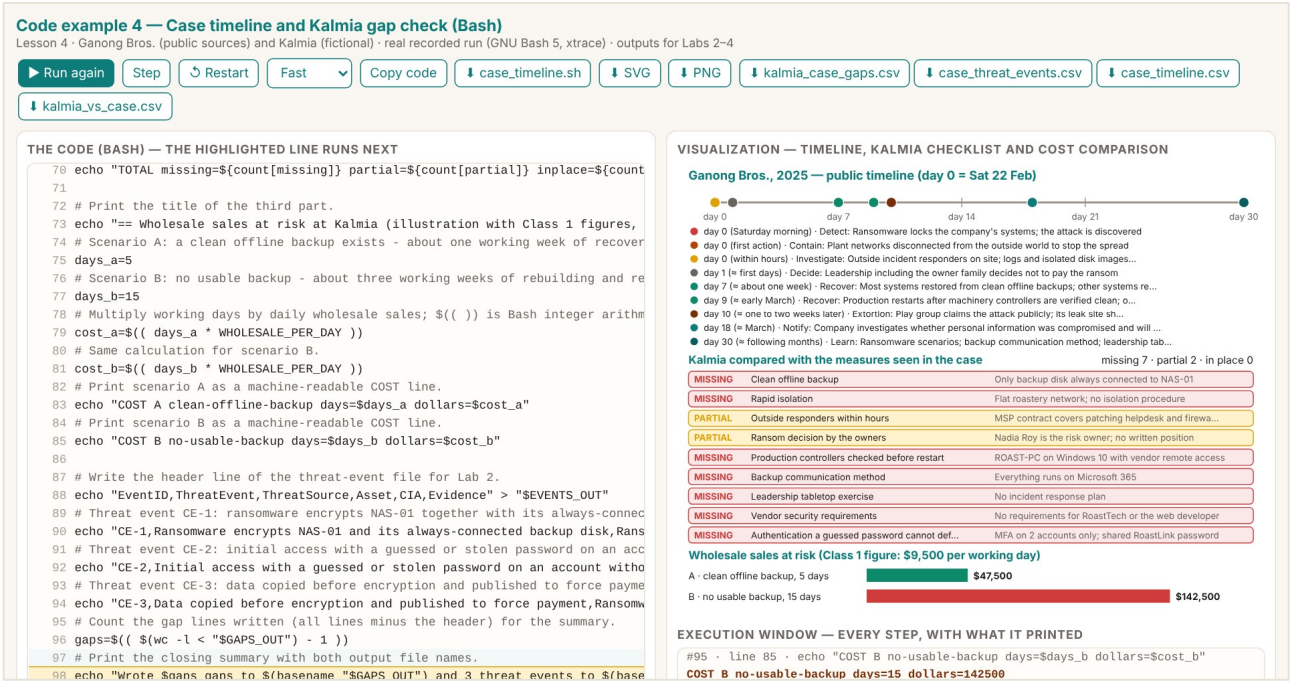
Professor Messer · 10:23 min · Watch on YouTube

Practice in the HTML module

5 flash-cards · formative quiz: 4 multiple-choice + 2 multiple-select questions

Code example 4 — case timeline and Kalmia gap check (Bash)

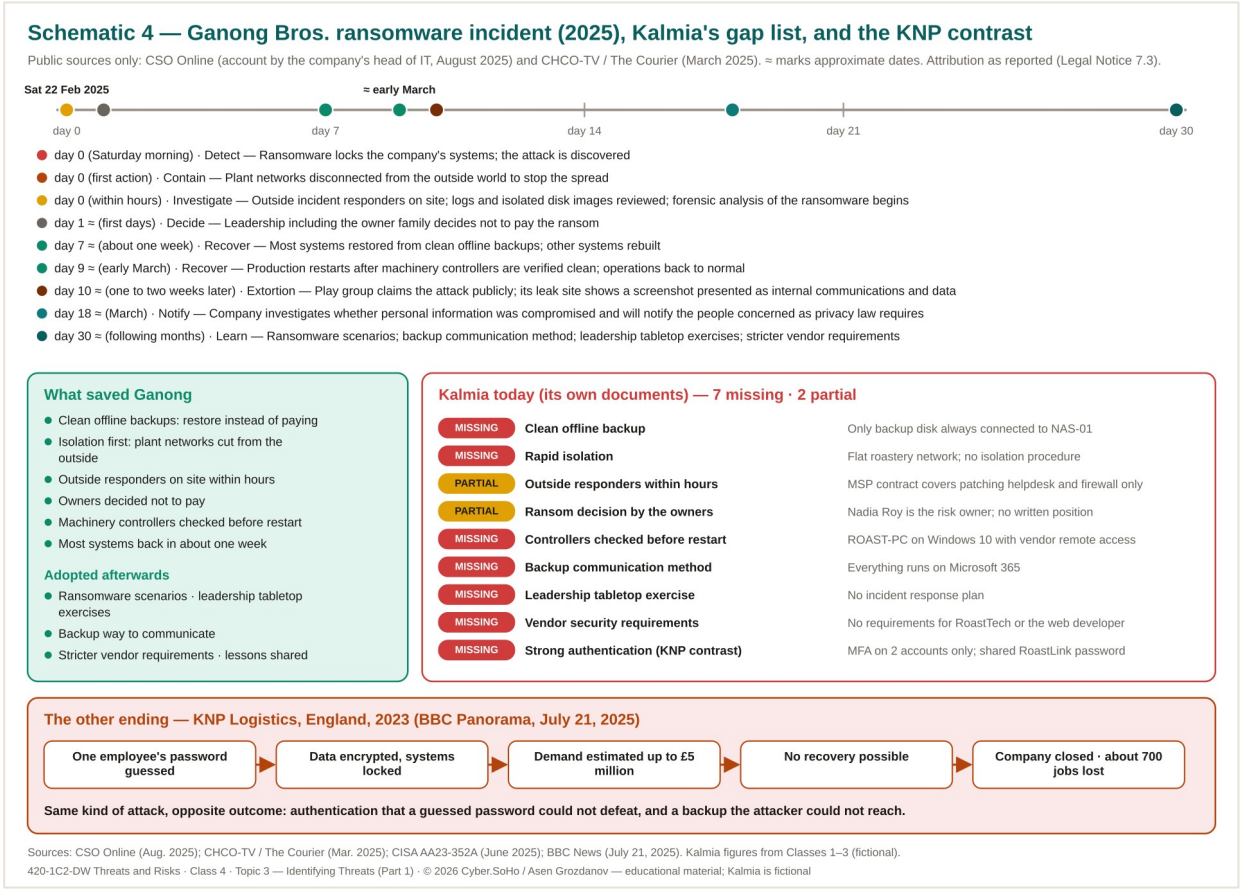
1. Reads case_timeline.csv (public timeline) and kalmia_vs_case.csv (9 measures)
2. Prints the dated timeline with the phase and the certainty of each event
3. Counts the measures in place, partial and missing (0 · 2 · 7)
4. Estimates wholesale sales at risk: 5 days ≈ $47,500 vs 15 days ≈ $142,500
5. Writes kalmia_case_gaps.csv (Labs 3–4) and case_threat_events.csv (Lab 2)



The interactive runner of the **HTML** module: Start / Pause, Step, Restart, Copy, downloads

Run it: bash case_timeline.sh (Linux, macOS or WSL [Windows Subsystem for Linux])

Schematic 4 — the case on one page

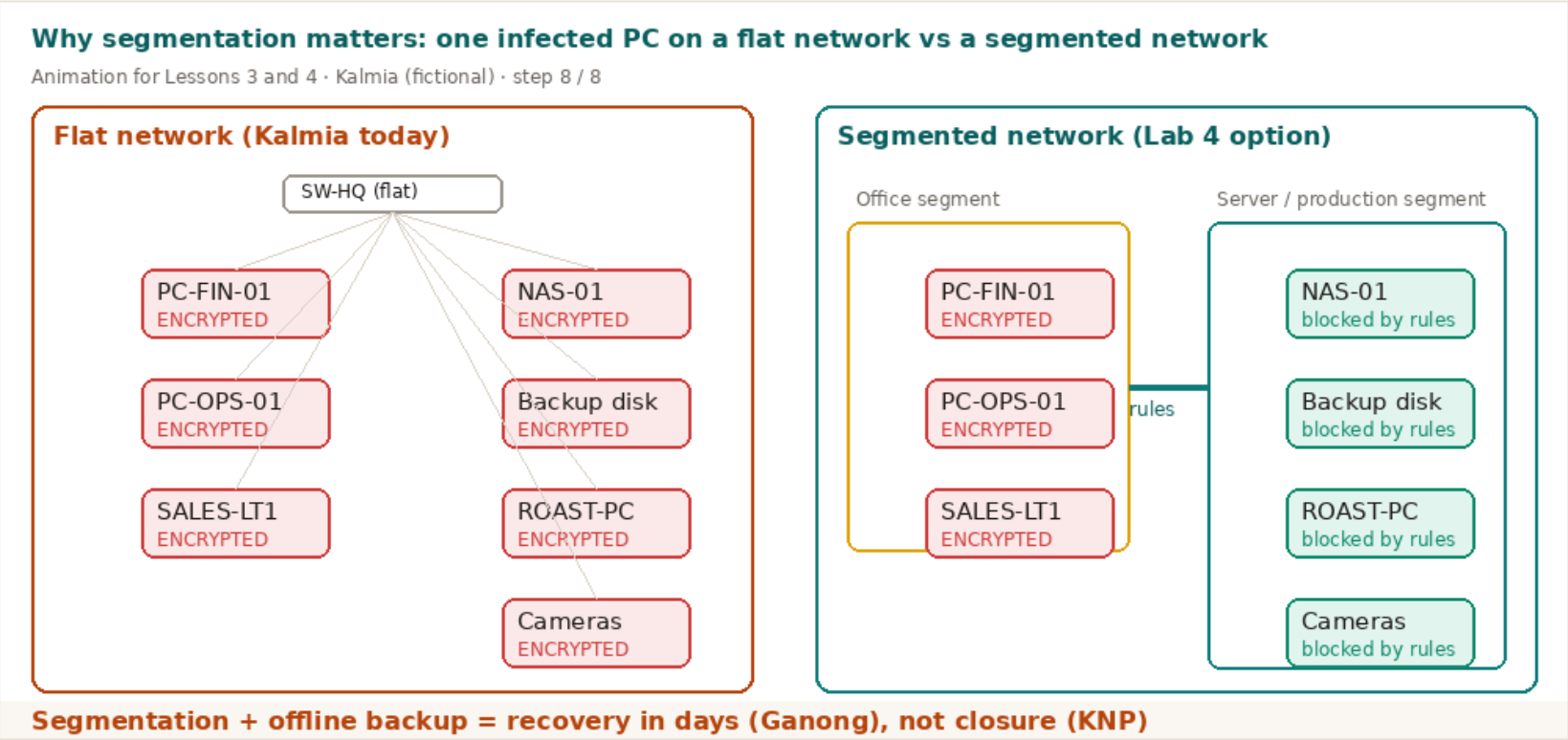


How to read it

- Top: the public timeline from discovery (day 0) to the lessons learned; ≈ marks approximate dates
- Bottom left: what saved Ganong and what it adopted afterwards
- Bottom right: the same measures at Kalmia today — 7 missing, 2 partial
- Last band: the KNP contrast — a guessed password and no recovery

Top: the public timeline from discovery to restoration, by phase, with the certainty of each date. Bottom left: what saved Ganong and what it adopted afterwards. Bottom right: the same measures at Kalmia today, and the KNP contrast (guessed password, no recovery).

Why segmentation matters — one infected PC, two networks



How to read it

- Left: Kalmia today — one switch, every device reachable
- Right: a segmented network — rules between the office and the server / production segments
- Watch where the infection stops
- Segmentation is a Lab 4 option; the offline backup is the other half

Animation (plays in PowerPoint): on the flat network one infected **PC** (personal computer) reaches NAS-01, the backup disk, ROAST-PC and the cameras; on a segmented network rules stop the spread.

After the lecture — tonight and this week

Quiz 01	Administered separately on the course platform — not part of this module
Hours 2–3	In teams: run Code examples 1 to 4, compare with the tables, add one Kalmia row to each
Lab 1 due	Thursday, November 5, 2026, 23:59 (Eastern Time), Léa drop box
Lab 2 starts	Class 5, Thursday: tonight's four **CSV** (comma-separated values) outputs are its starting rows
Before Class 5	Videos of Lessons 1–4, the flash-cards, the **NCTA** (National Cyber Threat Assessment) 2025-2026 executive summary

Key references — thank you

- National Cyber Threat Assessment 2025-2026 — Canadian Centre for Cyber Security
  https://www.cyber.gc.ca/en/guidance/national-cyber-threat-assessment-2025-2026
- An introduction to the cyber threat environment — Canadian Centre for Cyber Security
  https://www.cyber.gc.ca/en/guidance/introduction-cyber-threat-environment
- NIST SP 800-30 Rev. 1 — Guide for Conducting Risk Assessments
  https://csrc.nist.gov/pubs/sp/800/30/r1/final
- Defining Insider Threats — CISA
  https://www.cisa.gov/defining-insider-threats
- #StopRansomware: Play Ransomware (AA23-352A, updated June 4, 2025) — CISA, FBI, ASD's ACSC
  https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-352a
- Verizon 2025 Data Breach Investigations Report (DBIR) — news release with the key findings
  https://www.verizon.com/about/news/2025-data-breach-investigations-report
- Caught in the cyber crosshairs: A candy manufacturer's 2025 ransomware ordeal — CSO Online (August 2025)
  https://www.csoonline.com/article/4038381/caught-in-the-cyber-crosshairs-a-candy-manufacturers-2025-ransomware-ordeal.html
- Weak password allowed hackers to sink a 158-year-old company — BBC News (July 21, 2025)
  https://www.bbc.com/news/articles/cx2gx28815wo
- Ransomware: How to prevent and recover (ITSAP.00.099) — Cyber Centre
  https://www.cyber.gc.ca/en/guidance/ransomware-how-prevent-and-recover-itsap00099
- Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy (v2.0)
  https://cyber-soho.github.io/prevmon/00.01.%20cyber.soho%20-%20legal.html

Official sites only. Check any link on VirusTotal or Google Safe Browsing before opening it (Legal Notice 14.2, Annex C).

Thank you — see you in Hours 2 and 3.